CYBER SECURITY ASSESSMENT

Vulnerability Assessment Report

OWASP Juice Shop — Local Instance

PREPARED BY	YERRABHUMI CHANDRA SEKHAR REDDY
INTERNSHIP PROGRAM	Cyber Security Internship Future Interns
CIN ID	FIT/OCT26/CS10524
REPORT DATE	10 October 2026

REPORT PURPOSE

Document the security observations made while assessing a local OWASP Juice Shop training instance. Findings should be supported by captured traffic, scanner output, or browser evidence.

Executive Summary

A vulnerability assessment was conducted against the OWASP Juice Shop web application running locally on port 3000. The assessment identified three security weaknesses: two Medium-risk findings and one Low-risk finding.

03	02	01
Reported findings	Medium risk	Low risk

Key risk themes

The most significant issues are the absence of a Content Security Policy (CSP) header and an overly permissive Cross-Origin Resource Sharing (CORS) configuration. Both issues can increase exposure to client-side and cross-origin risks, depending on application behavior and affected endpoints.

No High-risk vulnerabilities were identified during this assessment. Overall risk posture: MEDIUM.

Assessment basis

This report summarizes the findings, risk ratings, and remediation recommendations documented for the local training instance. Evidence screenshots should be included for each finding before final submission.

Scope & Methodology

TARGET	http://localhost:3000 (OWASP Juice Shop)
TESTING PERIOD	10 October 2026
TOOLS	Nmap 7.95; OWASP ZAP 2.17.0; Mozilla Firefox Developer Tools
METHODOLOGY	Port and service detection with Nmap; OWASP ZAP web scanning and alert review; manual response-header inspection using Firefox Developer Tools.
SCOPE LIMITATION	Assessment was limited to the local Juice Shop instance. No authentication bypass or post-exploitation testing was performed.

Assessment steps

1. Confirm the local target and testing scope.
2. Use Nmap for port and service detection against the local instance.
3. Review OWASP ZAP alerts and captured HTTP traffic.
4. Inspect response headers and browser behavior using Firefox Developer Tools.
5. Document findings, assess impact, assign risk levels, and recommend remediation.

Finding 1

Content Security Policy (CSP) Header Not Set

RISK LEVEL: MEDIUM

Affected URLs

http://localhost:3000/
http://localhost:3000/ftp
http://localhost:3000/sitemap.xml

Evidence

The response is reported to omit the Content-Security-Policy HTTP header. Confirm this by capturing the response headers for the affected routes.

Description

The application does not send a Content-Security-Policy (CSP) header on the listed routes. CSP allows an application to define trusted sources for scripts, styles, images, and other resources.

Business impact

If a separate injection weakness exists, the absence of CSP removes a browser-enforced defense-in-depth control and may increase the impact of certain client-side attacks. The missing header alone does not prove an XSS vulnerability.

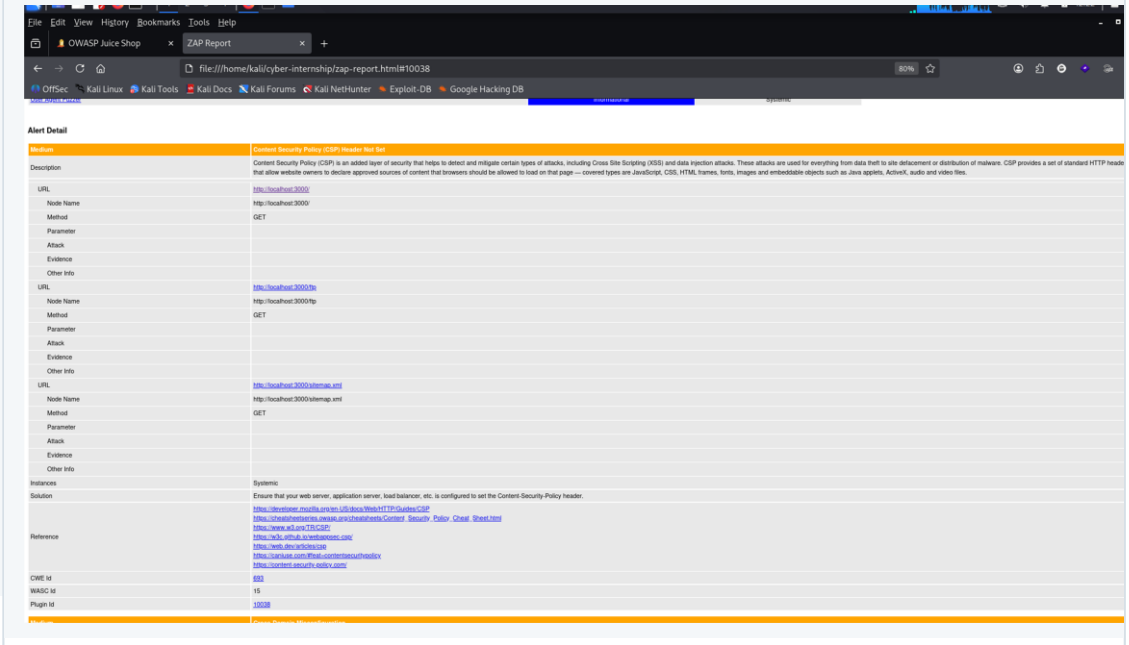
Remediation

Configure an application-appropriate Content-Security-Policy. Consider Report-Only mode during tuning, review violations, then enforce a restrictive policy. Retest application functionality after deployment.

Reference

CWE-693 — Protection Mechanism Failure; OWASP ZAP alert/plugin ID 10038.

EVIDENCE



Finding 2

Cross-Domain Misconfiguration — CORS

RISK LEVEL: MEDIUM

Affected URLs

http://localhost:3000/
http://localhost:3000/robots.txt
http://localhost:3000/sitemap.xml
http://localhost:3000/styles.css

Evidence

Response header: `Access-Control-Allow-Origin: *`. Capture the relevant response header and endpoint in the screenshot.

Description

The server sends a wildcard Access-Control-Allow-Origin header on the listed routes. A wildcard can permit browser-based cross-origin reads of eligible responses when credentialed access is not involved.

Business impact

If sensitive responses are accessible cross-origin, another website may be able to read them. Impact depends on the endpoint, sensitivity of the response, authentication model, and other CORS headers.

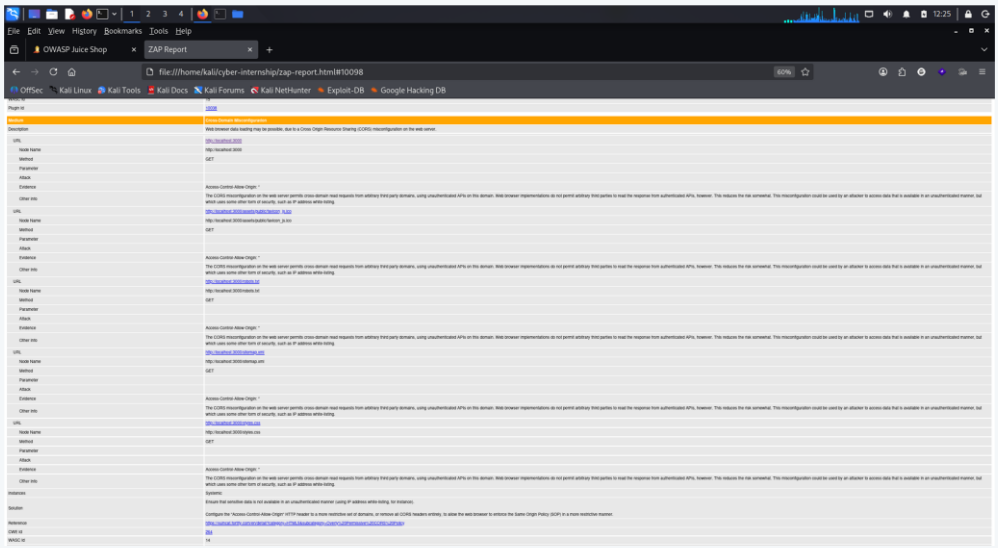
Remediation

Review which endpoints require cross-origin access. Remove unnecessary CORS headers or allow only trusted origins where needed. Do not combine wildcard origins with credentialed access. Retest approved and unapproved origins.

Reference

CWE-264 as referenced in the assessment; OWASP ZAP alert/plugin ID 10098. Confirm CWE and alert mapping against the installed ZAP version.

EVIDENCE



Finding 3

Timestamp Disclosure — Unix

RISK LEVEL: LOW

Affected URLs

http://localhost:3000/
http://localhost:3000/sitemap.xml
http://localhost:3000/styles.css

Evidence

Reported values: 1666666667, 1839622642, and 1528301887. Include response context in the screenshot to show where the values appear.

Description

The application responses contain Unix timestamp values. Verify the exact response body and timestamp interpretation before finalizing the finding.

Business impact

Public timestamps are often benign. They may provide reconnaissance context, but the values alone do not establish sensitive data exposure or an exploitable weakness.

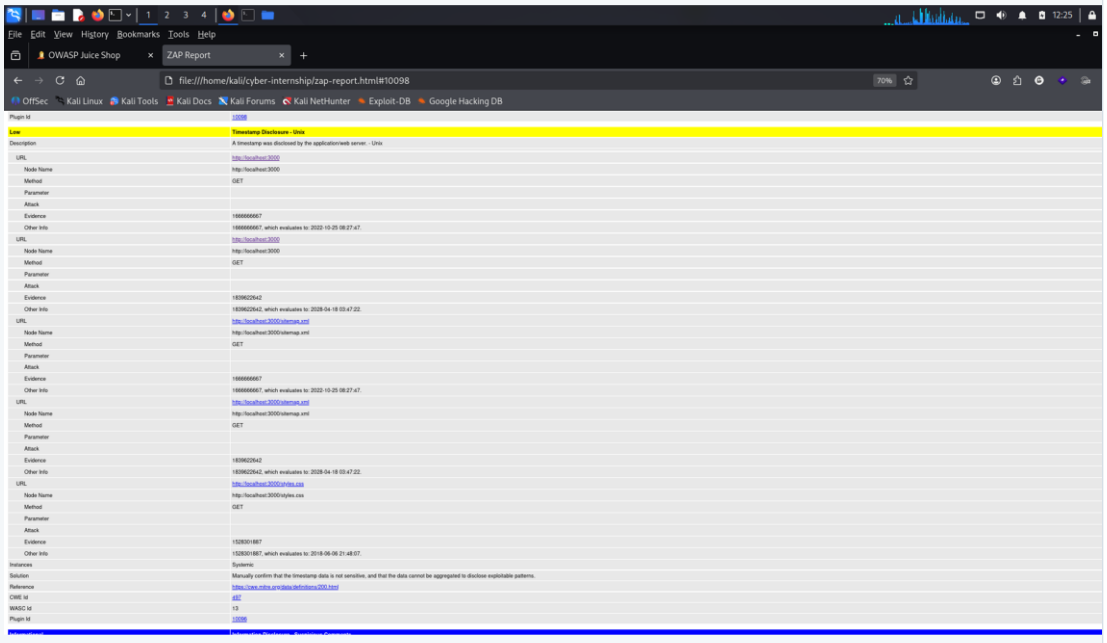
Remediation

Determine whether the timestamps are necessary for public functionality. Remove them only if they reveal sensitive operational details or have no legitimate purpose. Document the exact response context.

Reference

CWE-497; OWASP ZAP alert/plugin ID 10096. Verify the mapping and relevance to the observed values.

EVIDENCE



Informational Observations

The following observations were recorded as informational and do not, on their own, establish a vulnerability.

OBSERVATION	ASSESSMENT
Modern Web Application	JavaScript frameworks were detected. Framework identification alone is not a security issue.
Suspicious Comments	A code comment reportedly contained the word “query.” No sensitive data exposure was identified in the observation.
User-Agent Fuzzer	Different user-agent values reportedly returned equivalent responses. No security issue was identified.

Evidence handling

Retain the original ZAP report and relevant browser screenshots with the project files. Verify scanner alert details, URLs, response contents, and severity before submission.

Conclusion & Recommendations

Summary

The assessment identified three reported security weaknesses: missing CSP, permissive CORS, and Unix timestamp disclosure. The current ratings are two Medium and one Low. No High-risk vulnerabilities were identified in the assessment results described here.

Priority remediation order

PRIORITY	ACTION	RISK
01	Implement and test an appropriate Content-Security-Policy.	Medium
02	Restrict CORS to the minimum trusted origins needed.	Medium
03	Review whether timestamps expose meaningful sensitive operational details.	Low

Next steps

• Verify each finding against the original ZAP alert, response headers, and captured evidence.

• Apply appropriate fixes in the lab and retest to determine whether findings are resolved.

• Consider authenticated testing and deeper API security analysis in a separately scoped assessment.

• Publish the report and evidence in the required public GitHub repository. Do not include credentials, session cookies, or secrets